

2.1 PRD — Product Requirements Document

Phạm vi tài liệu: **EmeHub** (hub) và phần contract mà **Q-Agent** tiêu thụ. Chi tiết pipeline nội bộ của Q-Agent chỉ được mô tả ở mức cần thiết để hiểu contract.

Product Goals

#	Goal	Kiểm chứng bằng
G1	Một identity duy nhất cho cả suite	Login ở hub → vào agent không phải login lại; revoke session → logout mọi agent
G2	Credential khai một lần, dùng ở mọi agent, không rò rỉ	PAT không bao giờ xuất hiện trong response; Claude credential chỉ ra qua đúng một hàm
G3	AI có grounding về source thật trước khi sinh output	Knowledge base đạt trạng thái indexed là tiền đề của mọi bước sinh spec
G4	Con người giữ quyền quyết định ở các bước có hậu quả	Không case nào đi tiếp khi chưa approved
G5	Agent mới onboard không phải sửa hub	Audience mới đăng ký được; contract nằm trong INTEGRATION.md

Product Scope

Trong scope (hub): authentication + session + 2FA + user management; Claude credential (personal/shared, resolve, usage, refresh write-back); provider connection (Azure DevOps, GitHub, Jira) + capability binding + connection test; project/environment/test account/repository registry; knowledge base build + metadata + clone; ticket store + sync + server-side filter; agent registry + token/grant minting; audit log; landing page + admin console.

Trong scope (agent, để demo end-to-end): Q-Agent pipeline 7 bước, Review Center, live-harness authoring, Local Agent.

Ngoài scope: xem Out of Scope.

Functional Requirements

FR-1 Identity & Session

ID	Yêu cầu
FR-1.1	User đăng ký/đăng nhập bằng email + password (Argon2), role admin hoặc member
FR-1.2	TOTP 2FA bật/tắt được ở Profile
FR-1.3	Session gắn với một device: lưu refresh token đã hash, user agent, IP; liệt kê và revoke được
FR-1.4	Hub mint access token audience-scoped cho đúng một agent, mang sub, sid, aud, kid

FR-1.5	POST /auth/agent-token đổi refresh cookie lấy agent token mà không rotate refresh token
FR-1.6	Agent validate token local, không call ngược hub theo từng request
FR-1.7	Revoke một session làm invalid mọi agent token mang sid đó

FR-2 Claude Credential

ID	Yêu cầu
FR-2.1	User upload .credentials.json của Claude CLI; lưu encrypted at rest
FR-2.2	Admin publish credential ở scope workspace (shared)
FR-2.3	Resolve theo thứ tự own → shared → none; none trả về tường minh, không fail ngầm
FR-2.4	PUT /credentials/claude/mode đổi giữa personal và shared, không phải xoá credential
FR-2.5	PUT /credentials/claude/refreshed cho agent ghi lại token Claude CLI đã tự renew
FR-2.6	Hub lưu has_refresh_token (boolean, không lưu token); credential hết hạn nhưng renew được có status refreshable, không phải expired
FR-2.7	POST /credentials/claude/usage ghi token count + cost mỗi lần gọi; roll up thành % session limit và weekly limit
FR-2.8	Đúng một hàm trong hub trả credential material (resolve_material)

FR-3 Provider Connection

ID	Yêu cầu
FR-3.1	Tạo connection cho Azure DevOps / GitHub / Jira với PAT encrypted
FR-3.2	Credential-first: dán PAT → hệ thống liệt kê organisation → chọn organisation → đổ danh sách project
FR-3.3	Test connection chạy được trên bản nháp chưa lưu
FR-3.4	Connection khai báo capability work_item và/hoặc repository; project bind từng capability tới connection khác nhau
FR-3.5	GET /connections trả hasPat: true, không bao giờ trả PAT
FR-3.6	Hub proxy provider call qua endpoint hẹp theo từng operation; không có generic forwarder

FR-4 Project, Repository, Knowledge

ID	Yêu cầu
FR-4.1	Project có key, base URL, nhiều environment, test account (password encrypted, che trên UI), binding provider

FR-4.2	Repository thuộc project, phát hiện tự động từ connection đã bind hoặc thêm tay
FR-4.3	POST /projects/{key}/repos/{repo}/knowledge/build clone repo vào workspace theo owner và chạy project-bootstrap qua Claude CLI ở background
FR-4.4	Trạng thái not_indexed → indexing → indexed → stale hoặc error, kèm confidence score và lastError actionable
FR-4.5	Build bounded bởi EMEHUB_KNOWLEDGE_BUILD_CONCURRENCY (mặc định 2); indexing vừa là in-flight guard vừa là thứ UI poll
FR-4.6	PATCH knowledge cho agent ghi ngược selector verified-at-runtime; entry verified-at-runtime thẳng entry suy ra từ source, không bị ghi đè
FR-4.7	Member clone được project mẫu từ shared namespace: Project + ProjectConfig + ProjectKnowledge + artefact trên đĩa (knowledge/, repos/, auth/), re-stamp owner_id

FR-5 Ticket

ID	Yêu cầu
FR-5.1	Sync work item từ provider, normalise: external id, title, type, status, assignee, description, AC, comment, link
FR-5.2	Filter và paging phía server
FR-5.3	Cả hub và agent nhìn cùng một bản ghi ticket

FR-6 Agent Integration

ID	Yêu cầu
FR-6.1	GET /agents publish launch registry; phân biệt registered và handoffReady
FR-6.2	POST /auth/agent-grant cấp run-scoped grant cho background run — loại run không có browser và sống lâu hơn TTL 15 phút của access token
FR-6.3	Grant chỉ reach được đúng 3 route credential; giới hạn cường chế bằng wiring — không route nào khác depend require_credential_grant — chứ không bằng một nhánh điều kiện trong handler
FR-6.4	GET /connections/{id}/secret là endpoint duy nhất trả PAT, chỉ cho agent audience, cho hai case không có seam hub-side: clone repo và MCP config

FR-7 Q-Agent Pipeline (*agent side, cần cho demo*)

ID	Yêu cầu
FR-7.1	Pipeline 7 bước: Analyze & Generate → Review → Link → Automation → Execution → Evidence → Publish
FR-7.2	Test case sinh ra ở trạng thái pending; chỉ case approved đi tiếp
FR-7.3	Reviewer đổi được automation type từng case (Playwright / Selenium / Cypress / Manual); case Manual không bao giờ đem sinh spec
FR-7.4	Bước Link có local mode (dry-run): ghi local, không write lên provider

FR-7.5	Comment trả về ticket được preview trước, kèm status mapping cấu hình được
FR-7.6	Authoring mode live-harness (mặc định) và blind (self-heal, tối đa 3 lần)
FR-7.7	Placeholder gate pre-flight: selector bị, TODO stub, URL placeholder bị chặn; verdict passed / blocked / rejected
FR-7.8	Mỗi failure được gán failure class: test_defect / product_defect / flaky / environment / timeout
FR-7.9	Run hủy, chạy lại hoặc xóa được ở bất kỳ bước nào
FR-7.10	Local Agent: pairing code ngắn hạn → token per-device lưu tại ~/.qagent-agent/config.json, server chỉ giữ hash trên row AgentDevice; revoke được từ app

Non-Functional Requirements

ID	Loại	Yêu cầu
NFR-1	Security	EMEHUB_JWT_SECRET và EMEHUB_ENCRYPTION_KEY là hai secret riêng, không dẫn xuất từ nhau
NFR-2	Security	Thiếu secret → API refuse to start. Không sinh key lúc boot
NFR-3	Security	Không fail-open: không có cấu hình nào khiến "authentication không khả dụng" dẫn tới "cho vào"
NFR-4	Security	Không log và không trả secret ở bất kỳ endpoint nào
NFR-5	Privacy	Self-hosted. Dữ liệu ra ngoài chỉ có lời gọi tới Claude API
NFR-6	Audit	Mọi thao tác đáng ghi vào audit log append-only: category, actor + actor type, action, target, IP, status, run code
NFR-7	Cost	Mọi lần gọi Claude ghi token + cost, attribute theo owner; run bounded bởi cost ceiling, turn cap, wall-clock timeout
NFR-8	Reliability	Mọi schema change có Alembic migration; build knowledge fail luôn kết thúc ở error với lastError đọc được
NFR-9	Deployment	Cả suite sau một origin; agent mount theo path (/ , /qagent/)
NFR-10	Quality gate	uv run pytest xanh (788 hàm test); tsc -b --noEmit và vite build xanh
NFR-11	Accessibility	Light mode bắt buộc, contrast $\geq 4.5:1$ cho text
NFR-12	Compatibility	Desktop-first, canvas 1512×950. Mobile layout không nằm trong scope thiết kế

User Stories & Acceptance Criteria

US-1 — Đăng nhập một lần cho cả suite

Là một QC/QA, tôi muốn đăng nhập ở EmeHub và mở Q-Agent mà không phải đăng nhập lại.

AC

- Sau khi login ở hub, click Launch trên card Q-Agent thì vào thẳng Q-Agent ở trạng thái authenticated.
- Nếu EMEHUB_COOKIE_DOMAIN không phủ origin của agent, UI hiển thị agent là registered nhưng không handoffReady, và **không** hiện nút Launch dẫn tới lỗi sau click.
- Revoke session ở hub → refresh Q-Agent trả về màn login.

US-2 — Dùng Claude credential riêng hoặc dùng chung

Là một member, tôi muốn chạy AI bằng credential của mình, và fallback về credential chung khi tôi chưa upload.

AC

- Upload .credentials.json → chip credential trên header chuyển sang Personal.
- Chuyển sang shared bằng một toggle, không phải xoá credential đang có; chip đổi sang Shared ngay.
- Chưa có credential nào → chip hiển thị Not set, và thao tác cần Claude bị chặn với thông báo rõ, không fail giữa chừng.
- Credential quá expiresAt nhưng còn refresh token → status refreshable, run vẫn chạy được.
- Sau một run, usage của user tăng đúng phần token và cost của run đó.

US-3 — Kết nối Azure DevOps không phải gõ URL

Là một admin, tôi muốn dán PAT và hệ thống tự tìm ra organisation và project.

AC

- Dán PAT hợp lệ → dropdown organisation được đổ về; chọn organisation → dropdown project được đổ về.
- **Test connection** chạy được khi form còn là nháp chưa Save.
- Sau khi Save, GET /connections trả hasPat: true và không có trường nào chứa PAT.

US-4 — Build knowledge base cho một repository

Là một QC/QA, tôi muốn AI biết route và selector thật của project trước khi sinh spec.

AC

- Bấm Build → trạng thái chuyển indexing, UI hiển thị tiến độ theo bước.
- Hoàn tất → trạng thái indexed, có knowledge.md và knowledge.json, kèm confidence score.
- Source code đổi → trạng thái tự chuyển stale.
- Build fail → trạng thái error kèm lastError nói được nguyên nhân.
- Bấm Build lần hai khi đang indexing không tạo build thứ hai.

US-5 — Duyệt test case trước khi đi tiếp

Là một QC/QA, tôi muốn không có case nào được push lên Azure DevOps khi tôi chưa duyệt.

AC

- Case mới sinh có trạng thái pending.

- Bước Link chỉ nhận case approved; case pending hoặc rejected không xuất hiện ở payload.
- Đổi automation type sang Manual → case đó không được đem sinh spec.
- Mỗi case hiển thị mapping tới acceptance criteria mà nó cover.

US-6 — Spec chạy xanh ngay lần đầu

Là một QC/QA, tôi muốn spec sinh ra chạy được, không phải vòng sửa selector.

AC

- Ở mode live-harness, agent thực thi từng step trên app thật trước khi emit spec.
- Selector trong spec theo thứ tự ưu tiên data-testid → ARIA role + accessible name → label → CSS ổn định; không có :nth-child, class trần hay structural combinator.
- Spec chứa selector bị hoặc TODO bị placeholder gate chặn với verdict blocked hoặc rejected, kèm lý do hiển thị trên UI.
- Spec passed chạy lại được ở lần sau mà không cần sửa.

US-7 — Chạy test trên app sau SSO/MFA

Là một QC/QA, tôi muốn test app cần đăng nhập thật mà session không rời máy tôi.

AC

- Pair được máy tester bằng pairing code ngắn hạn; server chỉ lưu hash của device token.
- Spec chạy trên máy tester; cookie và storageState không được upload lên server.
- Chỉ spec, kết quả và evidence đi về server.
- Revoke device từ app → agent trên máy đó ngừng nhận job.

US-8 — Trả kết quả về ticket

Là một QC/QA, tôi muốn comment kết quả về ticket sau khi xem trước nội dung.

AC

- Comment được render preview trước khi gửi.
- Status mapping cấu hình được; không đổi status nếu không chọn.
- Evidence (screenshot, video, trace) truy cập được từ ticket.
- Mỗi failure có failure class hiển thị rõ, để một spec sai không bị đọc thành product bug.

Out of Scope

Không làm	Lý do
Chat interface trên hub	Hub không phải chat product; agent làm phần hội thoại
Workflow engine điều phối agent	Hand-off là hành động của người, rẻ vì context đã chia sẻ sẵn
Model gateway / proxy inference	Agent tự gọi Claude bằng credential resolve từ hub
Organisation / tenant entity thật	Dùng convention owner_id nullable + shared namespace; để mở tới Phase 2+

Mobile layout	Chưa thiết kế; desktop-first
Generic POST /connections/{id}/proxy	Bỏ hẳn, không hoãn — là bề mặt SSRF và header-leak
Sinh test, sinh code, tạo PR trên hub	Vi phạm boundary; thuộc về agent
SSO với IdP ngoài (Entra, Google Workspace)	Chưa lên lịch; thiết kế không chặn đường trở thành OIDC client sau này
D-Agent như một ứng dụng đang chạy trong bản dự thi	Là ví dụ kiểm chứng contract, không phải scope

Dependencies

Phụ thuộc	Dùng cho	Rủi ro nếu mất
Claude Code CLI (@anthropic-ai/claude-code)	Mọi bước AI ở cả hub và agent	Toàn bộ tính năng AI dừng
Anthropic API	Inference	Như trên; có cost ceiling và rate limit
Azure DevOps API (+ GitHub, Jira adapter)	Ticket, repository, test case	Không sync được ticket; pipeline dừng ở bước 1
PostgreSQL 16	Toàn bộ state	Không chạy
Playwright + Chromium	Live-harness và execution	Chạy trên Local Agent; image api cố tình không đóng gói chromium
Docker / Docker Compose	Triển khai suite sau một origin	Phải chạy từng service tay
Node 20 + git trong image API	project-bootstrap clone và build knowledge	Không build được knowledge base

Risks

#	Risk	Ảnh hưởng	Giảm thiểu
R1	Claude API đổi format credential hoặc siết rate limit	Run fail hàng loạt	Status refreshable tách khỏi expired; tín hiệu expired chỉ đến từ CLI bị reject thật; usage tracking cảnh báo trước khi chạm limit
R2	Knowledge base stale mà người dùng không để ý	Spec sinh sai selector	Trạng thái stale hiển thị rõ; placeholder gate chặn spec không có grounding
R3	Chi phí LLM vượt ngân sách	Không kiểm soát được	Cost ceiling + turn cap + wall-clock timeout mỗi run; usage attribute theo owner
R4	Hub là single point of failure cho credential	Mất hub là cả suite dừng	Agent validate token local nên không phụ thuộc hub từng request; ADR 0005 tách hai key; backup DB
R5	Agent cutover chưa hoàn tất — hub chạy song song	Cấu hình còn hai bản	Đã ship SSO cho Q-Agent (Phase 2); cutover credential và project là Phase 3–4

R6	AI sinh test case sai hoặc thiếu	Coverage giả	Review Center là gate bắt buộc; mapping AC → case hiển thị để reviewer thấy chỗ hở
R7	Live-harness cần app đang chạy và tài khoản test	Không dùng được ở môi trường đóng	Mode blind + self-heal là fallback
R8	Claude credential phải xuống disk của agent	Bề mặt rò rỉ	CLAUDE_SECURESTORAGE_CONFIG_DIR (hẹp) thay vì CLAUDE_CONFIG_DIR; run-scoped grant chỉ reach 3 route